MÁSTER EN ANÁLISIS DE MALWARE Y REVERSING
MÓDULO 7. DEBUG Y ANÁLISIS DEL SISTEMA OPERATIVO (LINUX)
TAREA 2

MÁSTER EN *ANÁLISIS DE MALWARE Y REVERSING*

Campus Internacional CIBERSEGURIDAD

ENIIT INNOVA IT BUSINESS SCHOOL

UCAM UNIVERSIDAD CATÓLICA DE MURCIA

1. ENUNCIADO

1.1. OBSERVACIONES

El proceso crypy es un criptolocker que ha cifrado parte del disco duro de nuestra máquina (mru8), sospechamos que para realizar el cifrado, ha generado al vuelo una pareja de claves pública/privada que ha enviado a su command and control. Ya que sospechamos que el proceso principal (ya ha finalizado su ejecución), mantuvo esta información en memoria, aún existe una posibilidad de obtener dicha clave y recuperar la información de la máquina.

1.2. OBJETIVOS

- Acceder vía SSH a la máquina con el usuario admin1 (contraseña: 1234) y utilizar los conocimientos aprendidos a lo largo del módulo (especialmente unidad 8.4) para obtener la clave privada del criptominer que ha atacado la máquina.
- Una vez localizada la clave privada usada para cifrar la máquina. Proceder a descifrar los archivos afectados (mysecrets.txt.encrypted) con el script creada para ello (crypy_decryptor.py). Dentro del script, completar la constante “PRIV_KEY” con la clave privada obtenida.

1.3. INFORMACIÓN DE UTILIDAD

- La lectura de la memoria puede arrojar resultados parciales, pero muy útiles si se consiguen recomponer los fragmentos necesarios para conseguir la información necesaria.
- Las claves privadas en formato RSA siempre comienzan y terminan por de la siguiente forma:
-

```
-----BEGIN RSA PRIVATE KEY-----

... contenido de la clave...

-----END RSA PRIVATE KEY-----
```

Ejemplo:


```
-----BEGIN RSA PRIVATE KEY-----

MIICXAIBAAKBgQCqGKukO1De7zhZj6+H0qtjTkVxwTCpvKe4eCZ0FPqri0cb2JZfXJ/DgYSF6vUp

wmJG8wVQZKjeGcjDOL5UlsuusFncCzWBQ7RKNUSesmQRMSGkVb1/3j+skZ6UtW+5u09lHNsj6tQ5

1s1SPrCBkedbNf0Tp0GbMJDyR4e9T04ZZwIDAQABAoGAFijko56+qGyN8M0RVyaRAXz++xTqHBLh

3tx4VgMtrQ+WEgCjhoTwo23KMBAuJGSYnRmoBZM3lMfTKevIkAidPExvYCdm5dYq3XToLkkLv5L2

pIIVOFMDG+KESnAFV7l2c+cnzRMW0+b6f8mR1CJzZuxVLL6Q02fvLi55/mbSYxECQQDeAw6fiIQX

GukBI4eMZZt4nscy2o12KyYner3VpoeE+Np2q+Z3pvAMd/aNzQ/W9WaI+NRfcxUJrmfPwIGm63il

AkEAxCL5HQb2bQr4ByorcMWm/hEP2MZzROV73yF41hPsRC9m66KrheO9HPTJuo3/9s5p+sqGxOlF

L0NDt4SkosjgGwJAFklyR1uZ/wPjjj611cdBcztlPdqoxssQGnh85BzCj/u3WqBpE2vjvyyvyI5k

X6zk7S0ljKtt2jny2+00VsBerQJBAJGC1Mg5Oydo5NwD6BiROrPxGo2bpTbu/fhrT8ebHkTz2epl

U9VQQSQzY1oZMVX8i1m5WUTLPz2yLJIBQVdXqhMCQBGoiuSoSjafUhV7i1cEGpb88h5NBYZzWXGZ

37sJ5QsW+sJyoNde3xH8vdXhzU7eT82D6X/scw9RZz+/6rCJ4p0=

-----END RSA PRIVATE KEY-----
```


2. INSTRUCCIONES DE PARTIDA

- Descargar la máquina en formato OVA del enlace asociado e importarla en VirtualBox preferiblemente.
- Aunque el ejercicio podría realizarse directamente a través de la consola servida por la máquina virtual en la tty1, es recomendable conectar con ella vía SSH con una consola nativa en el sistema operativo host. Para ello, en el caso de Windows podemos utilizar herramientas como Putty. En SO base Linux podremos utilizar directamente la consola.
- Verificar la IP que ha adquirido la máquina:
    - Cambiar el adaptador a Bridge (por defecto suele estar en NAT)
    - Conectar a la máquina directamente desde Virtualbox (opcionalmente cualquier otro SW de virtualización) usando admin1/1234

- Ejecutar el comando ifconfig y observar la salida para la interfaz **enp0s17**:

```
vm 1 [Corriendo]

mru8 login: admin2
Password:
Last login: Sun Feb 28 14:29:59 UTC 2021 on tty1
Welcome to Ubuntu 18.04.3 LTS (GNU/Linux 4.15.0-76-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

 System information disabled due to load higher than 1.0


54 packages can be updated.
0 updates are security updates.


admin2@mru8:~$ ifconfig
enp0s17: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.1.77  netmask 255.255.255.0  broadcast 192.168.1.255
        inet6 fe80::a00:27ff:feb1:3dd1  prefixlen 64  scopeid 0x20<link>
        ether 08:00:27:b1:3d:d1  txqueuelen 1000  (Ethernet)
        RX packets 154  bytes 11841 (11.8 KB)
        RX errors 0  dropped 2  overruns 0  frame 0
        TX packets 21  bytes 2378 (2.3 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 80  bytes 5920 (5.9 KB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 80  bytes 5920 (5.9 KB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

- Probar la conexión con la misma vía SSH usando admin2/1234 y sobre esa IP en una terminal en la máquina host

3. ENTREGABLES

Se debe generar un informe que incluya la siguiente información:

- Tras acceder a la máquina, documentar las pruebas llevadas a cabo para intentar localizar la huella en memoria (todas ellas) que ha dejado crypy. Incluir también, aquellas pruebas, que, aunque no hayan sido útiles en este caso, lo hubieran podido ser en otros similares.
- Una vez localizada la clave privada, incluir la información al respecto (donde se ha localizado, como se ha extraído, etc.) así como la propia clave.
- Una vez se deispone de la clave, lanzar el **script crypy_decryptor.py** que descifrará el fichero **mysecrets.txt.encrypted** almacenando en mysecrets.txt el texto original, que debe ser un mensaje con sentido. Incluir aquí el contenido de dicho fichero.

Nota: Acompañar en todo lo posible el informe con capturas ilustrativas de lo que se documente.